

公開技術白書

# ODRE PQC v0.2.9

Application-Embedded Post-Quantum Security Boundary

セキュリティ進化 ・ 脅威検証 ・ クロスプラットフォーム証拠

JAPANESE EDITION

2026年9月

# 目次

|    |                                                     |
|----|-----------------------------------------------------|
| 01 | 開発・セキュリティ進化<br>v0.1.1からv0.2.9                       |
| 02 | 脅威モデルとセキュリティ検証<br>Replay・Sequence・Native Identity   |
| 03 | プラットフォーム別検証<br>Windows Server 2022・Ubuntu 24.04 LTS |
| 04 | Artifactと証拠<br>封印Wheel・Runtime・根拠報告書                |
| 05 | 結論<br>観測された改善系譜と最終Artifact                          |

製品概要とアーキテクチャは別文書で扱い、本書はセキュリティ進化と実行証拠に集中する。

本書では製品概要および製品アーキテクチャを扱わない。これらは別文書 [ODRE PQC v0.2.9 製品概要およびセキュリティアーキテクチャ](#) で扱う。本書は、ODRE PQCの開発・セキュリティ進化、脅威モデル別の検証、プラットフォーム別の実行結果、封印Artifactと根拠資料の追跡関係を記録する。

# 1. 開発・セキュリティ進化

## 1.1 v0.1.1: 保護ルートの平文バイパス遮断

v0.1.1報告書は、直前の監査で [PQC-001 HIGH](#) に分類された保護ルート平文バイパスの是正結果を記録している。セキュリティランタイムが失敗した後も保護ルートがConsumer Handlerへ到達できる場合、暗号境界が失敗しているにもかかわらずアプリケーション機能が実行され得る。

v0.1.1は [/secure/\\*](#) をFail-Closedに固定し、セキュリティ失敗後のHandlerバイパスを遮断した。v0.1.1 Wheelの検証結果は次のとおりである。

- Wheel SHA-256: [627AF68632D5C99481849CB1C43497381267CCE426F3A5DA9752B069C36D37E6](#)
- RECORD完全性: 20/20
- Import Safety確認
- [install\(app\)](#) Plugin API確認
- 保護ルート方針: Fail-Closed
- セキュリティ失敗後のConsumer Handler実行: 0
- 公開ルートと保護ルートの分離確認
- Resource LifecycleおよびCleanup確認

この修正は後続バージョンの基本セキュリティ契約となった。以後の検証は、同じ試験の反復だけでなく、Replay、Request Binding、Native Runtime Trust、Crash Recovery、プラットフォーム固有攻撃へ拡張された。

## 1.2 v0.1.2: 機能検証通過後のClean-room攻撃試験で判明した3件の欠陥

v0.1.2には目的の異なる2つの報告書が残されている。製品検証報告書は、インストールAPI、Fail-Closedルート、ローテーション方針、セキュリティDBのトランザクション移行、終了時Drain、診断コマンド、クライアント往復を検査した。全体試験38/38、設定・ローテーション誤用37/37、起動・終了10サイクルを記録し、対象WheelのSHA-256は [59A562C789B28C05B309AAD0BC51511D9BD16D84A783021F1598A8AF21B4F06D](#) であった。

一方、同一Wheelを新規Python 3.12環境へハッシュ固定依存関係で導入した別のClean-room再検証では、セキュリティ攻撃試験20件中17件のみ通過した。インストール、実PQC正常経路、クライアント往復、RECORD 30/30、Resource Lifecycleは通過したが、3件の欠陥が再現された。機能・回帰試験の通過を攻撃面全体の通過へ拡張することはできなかった。

### 1.2.1 F-001: Sequence Gapの受容

試験ではSequence 5を保留したままSequence 6を送信した。期待動作は、Gapを含む要求を拒否し、保護Handlerを実行しないことである。しかしSequence 6はHTTP 200で受理され、保護Handler実行回数は3から4へ増加した。

問題は重複Replayだけではなく順序の連続性にある。重複値のみを遮断し、現在値より大きい値を許容すると、攻撃者は中間要求を飛ばしたり順序を乱したりしてもセッションを前進させられる。Sequence検証は単なる未使用値ではなく、正確に次の値であることを原子的に確認しなければならない。

## 1.2.2 F-002: Oversized Response判定前のHandler実行

保護Handlerが上限超過応答を生成する試験では、外部応答はHTTP 503でFail-Closedとなり、平文漏えいは観測されなかった。しかし応答サイズを拒否する前にHandlerが1回実行された。

問題は最終ネットワーク応答だけではない。HandlerはDB変更、外部呼出し、ファイル書込みなどの副作用を起こし得る。出力後に拒否しても副作用は発生済みとなるため、未対応の応答契約はHandler進入前に識別する必要がある。

## 1.2.3 F-003: Unsupported Streaming判定前のHandler実行

当時、Streaming、SSE、Iterator、WebSocketは保護応答契約で未対応であった。外部応答はHTTP 503で閉じ、平文漏えいもなかったが、対応可否を判定する前にHandlerが1回実行された。F-002と同じくFail-Closedの位置が遅すぎた。

v0.1.2 Clean-room報告書は監査中に製品を変更せず、3件の欠陥と観測値を保存した。修正とクローズ確認はv0.1.3の対象となった。

## 1.3 v0.1.3: Strict SequenceとPre-handler Contract Enforcement

v0.1.3はセキュリティ境界での強制順序を変更し、v0.1.2の3件をクローズした。

- Sequence Gap、Rollback、Duplicateをすべて拒否
- Oversizedまたは上限を事前確定できない保護応答契約をHandler実行前に拒否
- 未対応のStreaming、SSE、Iterator、WebSocketをHandler実行前に拒否

Clean-room再検証では、新規Python 3.12環境へ `--require-hashes` で導入し、`site-packages` のWheelを直接実行した。正常経路ではMock暗号ではなく、実OpenSSL 3.5.8のML-KEM-768およびML-DSA-65演算を使用した。

| 検証領域                       | 観測結果  |
|----------------------------|-------|
| セキュリティ攻撃試験                 | 20/20 |
| セキュリティ失敗後のHandler実行        | 0     |
| 誤設定試験                      | 6/6   |
| Wheel RECORD               | 31/31 |
| 新規Critical / High / Medium | 0/0/0 |

Gap、Rollback、Duplicate要求はすべて拒否され、保護Handler実行は0であった。Oversized、Unbounded、未対応StreamingもHandler前に拒否され、平文漏えいは観測されなかった。対象WheelのSHA-256は `EAA164895F835478441465112AAEEF8F6768740FFE2908BBE7CD53298D934D12` であった。

## 1.4 v0.1.4: 既存セキュリティ契約を後退させない観測機能の追加

v0.1.4は状態観測機能を追加しつつ、既存の保護境界が弱体化していないことを確認した。状態機能は製品試験15件と実Runtime独立確認4件を通過し、変更されていないv0.1.3セキュリティ試験41件も41/41で通過した。開発段階の結合結果は56/56であった。

Clean-room再検証の範囲:

- ハッシュ固定依存関係を用いた新規Python 3.12環境
- 導入済みWheelからの実行

- 実OpenSSL Runtime
- 実ML-KEM-768・ML-DSA-65正常経路
- セキュリティ攻撃試験: 20/20
- 誤設定試験: 6/6
- Handlerバイパス: 0
- RECORD: 32/32
- Status照会による状態変更: 0
- Status出力のSecret Leakage: 0
- 自動Classical Downgrade: 0
- 新規Critical / High / Medium: 0/0/0

対象WheelのSHA-256は [19EF222083C15D89E63B49A08D62EFEF480F3B82443839C900B6DAE425B13E54](#) であった。v0.1.4は新機能だけでなく、v0.1.2で失敗したSequenceとPre-handler条件も後続版で再確認した。

## 1.5 v0.1.2-v0.1.4 改善系譜

| バージョン  | 発見・変更                              | 攻撃または回帰リスク            | 構造的修正                                   | 再検証                                       |
|--------|------------------------------------|-----------------------|-----------------------------------------|-------------------------------------------|
| v0.1.2 | Sequence Gap受容                     | 要求順序攪乱後もセッション前進       | Strict next-sequence確認の必要性を確定           | Clean-room 17/20、失敗を保存                    |
| v0.1.2 | Oversized判定前にHandler実行             | 外部拒否前のアプリ副作用          | Pre-handler応答契約判定                       | v0.1.3 Handler実行0                         |
| v0.1.2 | Unsupported Streaming判定前にHandler実行 | 未対応型でも副作用             | 未対応型のPre-handler拒否                      | v0.1.3 Handler実行0                         |
| v0.1.3 | 3件を修正                              | 正常経路・Packagingを破壊する危険 | Strict Sequence・Pre-handler Enforcement | 攻撃20/20、設定6/6、RECORD 31/31                |
| v0.1.4 | 状態観測追加                             | 照会による状態変更・秘密漏えい       | Read-only・Secret-free Status契約          | Status 15+4、既存Security 41/41、RECORD 32/32 |

## 1.6 v0.2.4からv0.2.5: Ubuntu Native ABI欠陥

Windows検証を通過したv0.2.4をUbuntu実環境で試験したところ、Linux Shimに [odre\\_shutdown](#) Exportがないことが判明した。同一Python統合面でも、Native Runtime ABIはプラットフォーム別に検証すべきことを示した。

v0.2.5で修正・検証した項目:

- Ubuntu Shimの期待Export 15、実Export 15
- [odre\\_shutdown](#) Exportの存在
- Double ShutdownおよびStartup-Shutdown-Startup
- 5/5反復サイクル
- File Descriptor Delta: 0

- 終了後Shim Unmap
- OpenSSL 3.5.8 Runtime Identity
- 実ML-KEM-768・ML-DSA-65実行

その後のv0.2.5標的再監査でHigh 1件とMedium 2件が追加確認され、Release Blockingは維持された。原因と修正はv0.2.6系譜に属する。

## 1.7 v0.2.6: Native Trust、TOCTOU、FD Identity強化

v0.2.6の資料はBlind Static Audit、Targeted Reproduction、Confirmed Root Cause、Static-to-Dynamic Classification、Remediation、Final Multi-review Auditに分かれる。静的な疑念を直ちに欠陥とせず、攻撃Harnessで再現性を確認して分類した。

主な強化領域:

- ハッシュ対象と実ロード対象間のTOCTOU遮断
- パス文字列ではなく実FD・Inode Identityへの信頼結合
- Native ProviderとDependency Search Pathの検証
- 置換・再利用・Path Switch攻撃でVerified ObjectとLoaded Objectの同一性を証明
- 修正後、両プラットフォームで回帰試験を再実行

v0.2.6公式Wheel SHA-256は [4756FC9B219DAB4E2BF9C90FA066CFFD0D5DEA94FEF03DCE0B18DED55E5A7C7A](#) である。

## 1.8 v0.2.8からv0.2.9: F-028-01とParent Object置換防御

v0.2.8で [F-028-01](#) が確認された。脆弱な初期化経路では、昇格前の [Path.resolve\(\)](#) 結果が一時的なRoot Symlinkの影響を受ける可能性があった。

v0.2.9はLinuxで信頼済みParent Directory Chainを [O\\_DIRECTORY](#) | [O\\_NOFOLLOW](#) で開いて保持し、Staging Directory Identityを固定した後、Parent-dirfd相対 [renameat2\(..., RENAME\\_NOREPLACE\)](#) で昇格する。昇格後のDirectory ([st\\_dev](#), [st\\_ino](#)) がStaging Objectと一致することも確認する。必要なPrimitiveまたはIdentity Proofが利用できなければ初期化はFail-Closedとなる。

標的攻撃結果:

- Trials: 600
- Symlink Swaps: 1,212,203
- Exit Distribution: 成功278 / 安全な中断322
- Object-Path Misbinding: 0
- External-path Persistence: 0
- External-file Mutation: 0
- Secret Leakage: 0
- Partial Promoted State: 0

後続の全体監査では別のLate-promotion Parent-object Attackを600回実行した。攻撃状態600/600で初期化はFail-Closedとなり、Object-Path MisbindingとExternal Secret Stateはいずれも0であった。

## 2. 脅威モデルとセキュリティ検証

検証範囲:

1. Replay • Sequence競合
2. 要求 • 応答改ざん
3. Cross-session • Cross-path攻撃
4. Malformed • Oversized Input
5. HTTP Smuggling形状
6. Fuzz • Soak • Load
7. TOCTOU • FD • Inode Identity
8. Symlink • Junction • Reparse攻撃
9. Loaded-object Identity
10. Provider • Dependency • Config Injection
11. Worker Collision • Concurrent Init
12. Crash • Restart • Shutdown Lifecycle
13. Stale Session • Lease • Status再利用

### 2.1 Replay • Sequence競合 - 最終観測値

| プラットフォーム            | 重複要求  | Sequence当たり受理 | Double Handler Execution |
|---------------------|-------|---------------|--------------------------|
| Windows Server 2022 | 1,280 | 正確に1回         | 0                        |
| Ubuntu 24.04 LTS    | 2,880 | 正確に1回         | 0                        |

Replay試験はエラー応答の有無だけを判定しない。同一Sequenceが競合状態で到達した際、Application Handlerが2回実行されたかを別途計測した。

### 2.2 Native Loaded-object Identity - 最終観測値

Windowsでは実Provider • WinDLL Load 3,000回、成功したAtomic Replacement 1,062回、Junction作成 • 削除 3,000回を観測した。Untrusted DLL Load、Untrusted Dependency Load、Reparse Bypass、Verified-vs-loaded Identity Mismatchはいずれも0であった。

UbuntuではAtomic File • Parent • Symlink Swap、Unsafe Parent、Dependency • Provider • Module • Engine • Config Injection、FD • Inode Identity、50+50 Lifecycle Cycleを検証した。

## 3. プラットフォーム別検証

### 3.1 Windows Server 2022

- Windows Server 2022 AMD64

- CPython 3.12.10
- Hash-locked Offline Install
- [init](#)、Second-init Protection、[doctor](#)、[verify](#)、[status](#)
- 実ML-KEM-768 • ML-DSA-65 • Hybrid Handshake
- Request Semantic Binding • Response Metadata Boundary
- ACL Trust • Status Authentication • Shutdown Resource Lifetime
- Forced Termination • Second-crash Recovery

## 3.2 Ubuntu 24.04 LTS

- Ubuntu 24.04.4 LTS AMD64
- CPython 3.12.3
- Hash-locked Offline Install
- [init](#)、Second-init、[doctor](#)、Negative Doctor、[verify](#)、[status](#)
- 実ML-KEM-768 • ML-DSA-65 • Hybrid Handshake
- Admission Fuzz • Malformed • Oversized Input
- HTTP Smuggling Shape • WebSocket Fail-Closed
- Native Trust • Symlink • Parent Swap • FD/Inode Identity
- Graceful Shutdown • Restart • SIGKILL • Crash Recovery

# 4. Artifactと証拠

## 4.1 封印Wheel

- File: [odre\\_pqc-0.2.9-py3-none-any.whl](#)
- SHA-256: [A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697](#)
- RECORD: 45/45 Hashed Entry確認
- Package • Runtime Version: 0.2.9一致
- 監査開始 • 終了SHA-256一致

## 4.2 Native Runtime Archive

- Windows Runtime SHA-256: [826303E72A76B10041D26113F465ADD8960825C71F50722D6792174E73F9D12C](#)
- Ubuntu Runtime SHA-256: [EFAD16698203371D07F25B429F6731B9C0954EEBF5B58A0024789EF0611A78D1](#)

## 4.3 根拠報告書対応表

| 技術白書領域 | 主な根拠報告書                                                          |
|--------|------------------------------------------------------------------|
| v0.1.1 | <a href="#">ODRE PQC v0.1.1 - Independent Audit Evidence Log</a> |



| 技術白書領域        | 主な根拠報告書                                                                                                           |
|---------------|-------------------------------------------------------------------------------------------------------------------|
| v0.1.2-v0.1.4 | 各Version・Clean-room Reverification Report                                                                         |
| v0.2.0        | <a href="#">v0.2.0_FINAL_REPORT.md</a>                                                                            |
| v0.2.1        | <a href="#">v0.2.1_CUSTOMER_ZERO_CONFIG_BOOTSTRAP_REPORT.md</a> ,<br><a href="#">v0.2.1_FINAL_AUDIT_REPORT.md</a> |
| v0.2.5        | <a href="#">v0.2.5_FINAL_REPORT.md</a> , <a href="#">v0.2.5_REMEDIATION_HISTORY.md</a>                            |
| v0.2.6        | Blind Static・Targeted Repro・Root Cause・Remediation・Multi-review Reports                                           |
| v0.2.7        | Independent Audit・Remediation Reports                                                                             |
| v0.2.8        | F-027-01・RC03・F-028-01・Final Release Audit Reports                                                                |
| v0.2.9        | F-028-01 Targeted Remediation・Full Development Security Audit                                                     |

## 4.4 監査Harness問題と製品欠陥の分離

最終監査で確認された6件のHarness問題は製品欠陥と分離して保存された。FixtureとBindingを修正した後、製品Byteを変更せず関連Gateを再実行した。Harness Errorを製品成功または失敗へ自動解釈せず、修正後の再実行証拠を結果とともに保持した。

## 5. 結論

ODRE PQCのセキュリティ改善は一度の試験通過ではなく、失敗試験を保存し、その攻撃原因を後続版の構造変更へ結び付ける反復過程であった。v0.1.1は保護ルート平文バイパスを遮断し、v0.1.2のClean-room攻撃試験はSequence GapとHandler前検証順序の欠陥を明らかにした。v0.1.3はStrict SequenceとPre-handler Contract Enforcementでこれを閉鎖し、v0.1.4は観測機能追加後に既存セキュリティ契約を再確認した。

後続版は検証範囲をPython統合境界からNative RuntimeとOS別のObject Trust Boundaryへ拡大した。Ubuntu ABI欠落、検証対象と実ロード対象間のTOCTOU、FD・Inode Identity、Symlink・Junction・Reparse、Provider・Dependency・Config Injection、Crash・Restart・Shutdown Lifecycleを個別の攻撃条件として扱った。封印されたv0.2.9 Wheelは同一SHA-256を維持したままWindows Server 2022とUbuntu 24.04 LTSで再検証された。

最終識別対象は [odre\\_pqc-0.2.9-py3-none-any.whl](#)、SHA-256

[A8AFA10EE0AFACEF1C0FAF55FF07B96C722920E5AEE8692F6F026E804F028697](#) である。RECORD 45/45、監査開始・終了Artifact同一性、実OpenSSL 3.5.8 Runtime、ML-KEM-768、ML-DSA-65、Hybrid Handshake、Replay競合、Native Loaded-object Identity、Lifecycle試験がこのArtifactに対応付けられている。